



Assignment 3.1: Vulnerability Assessment Report

Christian Calipusan, Shivam Patel, Joshua Remington and Mikailou Nikiema

Shiley-Marcos School of Engineering (SMSE), University of San Diego

CYBR-514-01B: Cyber Engineering Research I

Professor Douglas Magedman

05/25/2026

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Executive Summary

Four Point Cyber Consulting conducted a vulnerability assessment of the Design World sandbox mirror environment to evaluate the security posture of systems supporting the organization's cloud based infrastructure and remote workforce operations. The assessment focused on identifying vulnerabilities, insecure configurations, exposed services, and weaknesses that may impact confidentiality, integrity, and availability across multiple network segments.

Assessment activities included vulnerability scanning, network enumeration, configuration analysis, and manual validation using tools such as Nessus, Nmap, Nikto, and OWASP ZAP. Multiple high and medium severity vulnerabilities were identified throughout the environment, particularly within the Business Subnet and Transit and Services VLAN. Key findings included weak SSL/TLS configurations, deprecated protocols, SMB weaknesses, exposed Telnet services, world readable NFS shares, and insecure authentication related configurations.

During web application testing, the assessment team also encountered intermittent accessibility issues affecting the Website Subnet web server, limiting automated testing through Nikto and OWASP ZAP. Although Apache services were confirmed operational internally, external HTTP connectivity initially failed and required additional troubleshooting.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Overall, the assessment identified several opportunities to strengthen Design World's security posture through improved patch management, service hardening, protocol modernization, and segmentation validation.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Table of Contents

1. Scope.....	4
2. Objectives and Goals.....	5
3. Method Overview.....	6
3.1 Nessus Scan.....	6
3.2 Nmap Scans.....	7
3.3 Web Application Testing.....	8
4. High-Level Findings.....	10
4.1 Public Subnet.....	10
4.2 Business Subnet.....	10
4.3 Website Subnet.....	11
4.4 Transit and Services VLAN.....	12
5. Detailed Findings.....	13
5.1 Business Subnet Findings.....	13
5.2 Missing Windows Server Security Updates.....	14
5.3 Weak SSL/TLS Configuration.....	15
5.4 SMB Security Weaknesses.....	16
5.5 Unencrypted Telnet Service.....	17
5.6 World Readable NFS Shares.....	18
5.7 Website Service Accessibility Issues.....	18
5.8 Penetration Testing Handoff.....	20
6. Conclusion and Next Steps.....	22
7. Approvals.....	24

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

1. Scope

The scope of this Vulnerability Assessment Report is limited to the Design World sandbox mirror environment hosted within the Linode cloud infrastructure. The assessment was conducted by Four Point Cyber Consulting to evaluate the security posture of systems representing a single Design World production region. Testing activities focused on identifying vulnerabilities affecting confidentiality, integrity, and availability across the segmented cloud architecture.

Assessment activities were performed remotely through an encrypted OpenVPN connection using authorized assessment systems. The engagement included evaluation of the following network segments and associated assets:

- Public Subnet (172.16.200.0/24)
- Business Subnet (172.16.1.0/24)
- Website Subnet / DMZ (172.16.10.0/24)
- Transit and Services VLAN (192.168.100.0/24)

Systems assessed during the engagement included:

- OpenVPN Server
- Windows Server 2022 Domain Controller
- Windows Server 2022 File Server

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

- Ubuntu 22.04 Workstation
- CentOS Stream 9 Web Server

Assessment activities included vulnerability scanning, network enumeration, configuration analysis, and manual validation of identified findings. Exploitation activities, denial of service testing, persistence mechanisms, and destructive testing procedures were outside the scope of this engagement.

2. Objectives and Goals

The objective of this assessment was to evaluate the overall security posture of the Design World environment and identify vulnerabilities that could expose the organization to unauthorized access, service disruption, or data compromise.

Specific goals included:

- Identify critical, high, medium, and low severity vulnerabilities
- Detect insecure protocols and outdated cryptographic configurations
- Evaluate exposed services and unnecessary network accessibility
- Assess authentication and encryption weaknesses
- Identify web server and web application issues
- Analyze segmentation effectiveness between network zones

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

- Provide remediation recommendations to strengthen system security
- Support future penetration testing and infrastructure hardening efforts

The assessment also aimed to determine whether externally accessible systems and internally exposed services could be leveraged by attackers during reconnaissance or exploitation activities.

3. Method Overview

In our vulnerability assessment, our method was carefully chosen to ensure a thorough analysis of Design World's IT infrastructure. Four Point Cyber Consulting's approach used the strengths of Nessus and Nmap, along with web application testing tools such as Nikto and OWASP ZAP.

3.1 Nessus Scan

Nessus was the primary tool used for vulnerability scanning throughout the engagement. Nessus provided detailed identification of vulnerabilities, insecure protocols, weak cipher suites, exposed services, and system configuration issues across the environment.

The scans identified:

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

- SSL/TLS weaknesses
- SMB configuration issues
- Deprecated protocols
- SSH weaknesses
- Telnet exposure
- NFS misconfigurations
- Information disclosure findings

Nessus scans were conducted against systems located within the Business Subnet, Public Subnet, Website Subnet, and Transit and Services VLAN. The Nessus reports identified multiple high and medium severity vulnerabilities across several hosts.

3.2 Nmap Scans

Nmap was used for network mapping, service enumeration, and port discovery. The following scan format was used during enumeration:

```
nmap -Pn -sV <target-ip>
```

The `-Pn` flag treated hosts as online, which was useful in environments where ICMP filtering may exist. The `-sV` option enabled service version detection to identify running services and potential outdated software.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Nmap scanning helped identify:

- Open ports
- Running services
- SSH accessibility
- HTTP services
- SMB services
- RPC and FTP exposure
- Web server availability

The scans provided additional visibility into attack surfaces that could potentially be leveraged by attackers.

3.3 Web Application Testing

Web application testing was attempted against the CentOS web server located in the Website Subnet (172.16.10.50). Initial testing was conducted using Nikto with the following command:

```
nikto -h http://172.16.10.50
```

Additional testing was attempted using OWASP ZAP to perform automated web application scanning and spidering.

 FOUR POINT — CYBER CONSULTING —		Vulnerability Assessment Report		Client	Design World
				Doc #	DW0003
Effective Date	05/25/26			Rev. #	Rev 1

During testing, several issues were encountered:

- Successful ICMP ping responses
- Apache web service confirmed active internally
- Port 80 confirmed listening locally on the server
- External TCP connectivity to port 80 initially failed
- OWASP ZAP scans repeatedly timed out
- Nikto scanning attempts failed intermittently due to service accessibility issues

Further troubleshooting confirmed that Apache was actively running on the CentOS server using:

```
systemctl status httpd
```

Testing later confirmed that TCP port 80 connectivity eventually succeeded after troubleshooting connectivity and service accessibility issues. However, intermittent accessibility problems indicated possible firewall restrictions, routing issues, or unstable service exposure between network segments.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

4. High-Level Findings

4.1 Public Subnet

The Nessus scan of the Public Subnet identified mostly informational findings with one low severity vulnerability related to ICMP Timestamp Request Remote Date Disclosure. Multiple SSH related informational findings were also identified, including SSH SHA-1 HMAC algorithms enabled and SSH password authentication acceptance.

Although no critical vulnerabilities were identified in this subnet, the exposed SSH related configurations and information disclosure findings increase reconnaissance visibility for attackers.

4.2 Business Subnet

The Business Subnet contained the largest concentration of vulnerabilities identified during the assessment. Nessus scans identified multiple critical, high, and medium severity vulnerabilities affecting Windows and Linux systems. Key findings included weak SSL/TLS configurations, SMB weaknesses, deprecated protocols, missing security updates, and insecure authentication related settings.

The Windows based systems contained vulnerabilities related to SMBv1 exposure, insecure TLS configurations, self-signed certificates, and deprecated TLS 1.0 and TLS

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

1.1 protocols. Linux systems also demonstrated SSH related weaknesses and insecure service configurations.

These findings represent elevated risk because the Business Subnet supports core operational systems and centralized business services.

4.3 Website Subnet

The Website Subnet scan identified mostly informational findings and one low severity vulnerability related to ICMP Timestamp Request Remote Date Disclosure. SSH related informational findings were also detected, including SSH SHA-1 HMAC algorithms enabled and SSH password authentication acceptance.

During manual validation, the assessment team experienced intermittent connectivity issues when attempting web application testing against the CentOS web server. Although Apache was confirmed operational locally, external connectivity to port 80 initially failed, preventing reliable OWASP ZAP and Nikto scanning.

This issue suggests possible firewall filtering, network segmentation restrictions, or unstable HTTP service accessibility affecting the Website Subnet. Because the web server represents the Website/DMZ layer, follow-up validation should confirm whether the issue is caused by routing, firewall rules, service binding, or segmentation controls.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

4.4 Transit and Services VLAN

The Transit and Services VLAN contained several findings that are important to Design World's internal routing, DNS forwarding, and inter-subnet communication. Unlike the Public and Website subnets, the Transit and Services VLAN presented findings that could support internal reconnaissance, lateral movement, or insecure administrative communication if exploited by an attacker with internal access.

Key findings included weak SSL/TLS configurations, deprecated TLS protocols, self-signed certificates, SSH related weaknesses, SMB weaknesses, DNS cache snooping, world readable NFS shares, and an unencrypted Telnet service. These findings are significant because the Transit and Services VLAN supports communication between the OpenVPN entry point and internal systems.

The most significant Transit VLAN findings were observed on systems associated with the Domain Controller, File Server, Ubuntu workstation, and OpenVPN routing services. These findings should be prioritized for remediation because the Transit VLAN plays a central role in maintaining secure access boundaries between the Public, Business, and Website/DMZ subnets.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

5. Detailed Findings

5.1 Business Subnet Findings

Severity Overview

The Business Subnet contained the highest number of significant findings identified during the assessment. Vulnerabilities included weak cryptographic protocols, SMB related weaknesses, self-signed certificates, deprecated TLS versions, and insecure authentication related configurations.

Key Findings:

- SSL Medium Strength Cipher Suites Supported (SWEET32)
- TLS 1.0 and TLS 1.1 enabled
- SMBv1 enabled
- SMB signing not required
- Self-signed SSL certificates
- SSH Terrapin Prefix Truncation Weakness (CVE-2023-48795)
- Terminal Services without Network Level Authentication

Risk

Attackers may leverage these weaknesses to perform credential attacks, relay attacks, downgrade attacks, or unauthorized lateral movement within the environment.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Recommendation

- Disable SMBv1
- Enforce SMB signing
- Remove deprecated TLS protocols
- Replace self-signed certificates with trusted certificates
- Harden Remote Desktop configurations
- Implement stronger authentication controls

5.2 Missing Windows Server Security Updates

Affected System: 172.16.1.10, 172.16.1.20

Severity: Critical

Description

The Nessus scans identified multiple missing Microsoft Windows Server 2022 security updates on the Domain Controller and File Server. These updates included critical and high severity patches associated with Windows Server and Microsoft .NET Framework components. The most significant example selected for further validation in the Penetration Testing Plan is KB5012604, which was identified as a Critical finding.

Risk

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Missing critical security updates increase the likelihood that known vulnerabilities could be exploited by attackers. On systems such as the Domain Controller and File Server, successful exploitation could result in unauthorized access, privilege escalation, system compromise, or exposure of sensitive Design World data. Because these systems support identity management and file storage, patching gaps present a direct risk to confidentiality, integrity, and availability.

Recommendation

Design World should apply all missing Microsoft security updates to the Domain Controller and File Server. Patch deployment should be prioritized based on severity, system role, and exposure level. After patching is completed, Four Point Cyber Consulting recommends conducting follow-up vulnerability scans to confirm remediation and identify any remaining update gaps.

5.3 Weak SSL/TLS Configuration

Affected Systems: 192.168.100.10, 192.168.100.20

Severity: High

Description

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Nessus identified SSL Medium Strength Cipher Suites Supported (SWEET32) vulnerabilities on multiple systems. Deprecated TLS 1.0 and TLS 1.1 protocols were also enabled.

Risk

Weak cipher suites and deprecated TLS protocols may allow attackers to weaken encrypted communications and perform cryptographic attacks against sensitive traffic.

Recommendation

- Disable TLS 1.0 and TLS 1.1
- Enforce TLS 1.2 or higher
- Remove weak cipher suites
- Replace self-signed certificates with trusted certificates

5.4 SMB Security Weaknesses

Affected System: 192.168.100.20

Severity: Medium

Description

The scan identified SMB signing not required and SMBv1 enabled on the affected host.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Risk

Attackers may leverage SMB weaknesses for relay attacks, unauthorized access, or lateral movement within the network.

Recommendation

- Disable SMBv1
- Enforce SMB signing
- Restrict SMB exposure to authorized hosts only

5.5 Unencrypted Telnet Service

Affected System: 192.168.100.40

Severity: Medium

Description

An unencrypted Telnet service was detected on the host.

Risk

Telnet transmits credentials and session traffic in plaintext, making it vulnerable to interception and credential theft.

Recommendation

- Disable Telnet services

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

- Replace Telnet with SSH for encrypted administrative access

5.6 World Readable NFS Shares

Affected System: 192.168.100.40

Severity: High

Description

Nessus identified NFS shares configured with world readable permissions.

Risk

Unauthorized users may access shared files and sensitive information without authentication.

Recommendation

- Restrict NFS access to authorized hosts
- Implement authentication and export restrictions
- Review file share permissions

5.7 Website Service Accessibility Issues

Affected System: 172.16.10.50

Severity: Medium

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

Description

The assessment team experienced intermittent failures when attempting to access the CentOS web server using Nikto and OWASP ZAP. Apache was confirmed operational internally, but external HTTP connectivity initially failed despite successful ping responses.

Evidence

Observed during testing:

- Successful ping responses
- Apache service active and running
- Port 80 listening internally
- External TCP connectivity failures
- OWASP ZAP timeout errors
- Nikto connection failures

Risk

Unstable web service accessibility may indicate firewall misconfigurations, segmentation issues, or improper HTTP exposure controls that could impact both security visibility and service availability.

Recommendation

- Review firewall rules affecting HTTP traffic

 FOUR POINT — CYBER CONSULTING —	Vulnerability Assessment Report		Client	Design World
			Doc #	DW0003
			Rev. #	Rev 1
Effective Date	05/25/26			

- Validate inter-subnet routing configurations
- Confirm web service exposure policies
- Conduct follow-up web application testing after remediation

5.8 Penetration Testing Handoff

Based on the results of the vulnerability assessment, Four Point Cyber Consulting recommends that the penetration testing phase focus on vulnerabilities that present the highest potential impact to Design World's business operations, identity infrastructure, and sensitive data repositories. Not every vulnerability identified during scanning should be exploited. Instead, penetration testing should validate selected findings that could support unauthorized access, privilege escalation, lateral movement, or exposure of sensitive information.

Recommended penetration testing focus areas include:

Priority Area	Related Finding	Reason for Penetration Testing
Domain Controller	Missing Windows Server security updates, weak authentication settings, insecure service permissions	The Domain Controller supports centralized identity and access management. Successful exploitation could affect

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

		the broader environment.
File Server	Missing Windows Server security updates, SMB signing not required, NTLMv1 enabled	The File Server supports sensitive internal data access and may expose Design World intellectual property if compromised.
Ubuntu Workstation	World-readable NFS shares, OpenSSL vulnerabilities, Telnet exposure	These findings may support unauthorized data access, insecure communication, or lateral movement.
Transit and Services VLAN	DNS cache snooping, weak TLS, SMB exposure, NFS and Telnet findings	This VLAN supports routing and internal service communication. Weaknesses may support reconnaissance or pivoting.
Website/DMZ Server	Intermittent HTTP accessibility, incomplete Nikto and OWASP ZAP testing	Web service accessibility issues should be validated to determine whether firewall, routing, or service configuration problems exist.

The penetration testing phase should use a controlled, approved approach and focus on validating exploitability without disrupting system availability. Findings that are not selected for exploitation should still be tracked for remediation during the hardening phase.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

6. Conclusion and Next Steps

The vulnerability assessment identified several security weaknesses affecting the Design World environment, particularly within the Business Subnet and Transit and Services VLAN. Major findings included insecure SSL/TLS configurations, deprecated protocols, SMB weaknesses, exposed Telnet services, world readable NFS shares, and web service accessibility issues.

While several systems demonstrated relatively low risk exposure, multiple hosts contained weaknesses that could support reconnaissance, credential compromise, lateral movement, or unauthorized access if exploited by attackers.

The web server accessibility issues encountered during Nikto and OWASP ZAP testing also highlighted potential network segmentation or firewall configuration concerns that should be reviewed further.

Recommended next steps include:

- Disable deprecated protocols and weak cipher suites
- Remove SMBv1 and enforce SMB signing
- Disable Telnet services
- Restrict NFS share permissions

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

- Harden SSH configurations
- Review firewall and segmentation policies
- Revalidate HTTP accessibility for web application testing
- Conduct remediation validation scans after fixes are applied

Addressing these findings will improve Design World's overall security posture and reduce the organization's exposure to internal and external threats.

		Vulnerability Assessment Report	Client	Design World
			Doc #	DW0003
Effective Date	05/25/26		Rev. #	Rev 1

7. Approvals

Role	Printed Name	Signature	Date
Project Lead	Christian Calipusan	<i>Christian Calipusan</i>	05/25/26
Security Analyst	Shivam Patel	<i>Shivam Patel</i>	05/25/26
Security Engineer	Joshua Remington	<i>Joshua Remington</i>	05/25/26
Network Engineer	Mikailou Nikiema	<i>Mikailou Nikiema</i>	05/25/26
DW CEO			